Informativa sul trattamento dei dati personali dei dipendenti

Ai sensi degli articoli 13 e 14 del Regolamento (UE) 2016/679 (GDPR)
Applicativo: HR-Tech ERP
Versione: 1.0
Data di aggiornamento: 5 ottobre 2026

1. Titolare del trattamento e contatti

Il Titolare del trattamento è **[RAGIONE SOCIALE]**, con sede legale in **[INDIRIZZO COMPLETO]**, C.F./P.IVA **[CODICE FISCALE/PARTITA IVA]**, e-mail **[E-MAIL PRIVACY]** (di seguito, il **Titolare**).

Il Titolare può essere contattato per qualsiasi richiesta relativa al trattamento dei dati personali e all'esercizio dei diritti descritti nella presente informativa.

Se nominato, il Responsabile della protezione dei dati (DPO/RPD) è contattabile all'indirizzo **[E-MAIL DPO]**.

2. A chi si applica e come sono raccolti i dati

La presente informativa riguarda dipendenti e, ove presenti nell'applicativo, collaboratori e altri lavoratori gestiti dal Titolare tramite HR-Tech ERP.

I dati sono raccolti:

- direttamente dall'interessato, tramite l'applicativo o comunicazioni al Titolare;
- dal personale autorizzato del Titolare, per la gestione anagrafica, contrattuale e delle presenze;
- tramite il dispositivo aziendale utilizzato per la timbratura con QR Code;
- quando necessario, da soggetti autorizzati o da documenti forniti dall'interessato, per giustificare assenze o trasferte.

Quando i dati non sono raccolti direttamente dall'interessato, l'informativa è resa anche ai sensi dell'articolo 14 GDPR, nei limiti e con le modalità applicabili.

3. Categorie di dati trattati

In base alle funzionalità effettivamente presenti nel progetto, l'applicativo può trattare:

- **dati identificativi e di contatto:** nome, cognome, e-mail aziendale, identificativo utente e dati necessari a collegare l'utenza al dipendente;

- **dati fiscali e retributivi/contrattuali:** codice fiscale, IBAN, livello, mansione, tipologia e scadenza del contratto, data di assunzione, percentuale part-time, orario teorico e profilo di calcolo;
- **dati relativi alla presenza e all'organizzazione del lavoro:** data, orario di ingresso e uscita, pause, ore ordinarie, eccedenti e straordinarie, turnazione/orario settimanale, modalità di lavoro (in sede, smart working o trasferta), fonte della rilevazione (manuale o QR Code), stato di invio e approvazione;
- **dati relativi ad assenze e causali:** ferie, permessi, malattia, maternità, infortunio, cassa integrazione, assemblea e sciopero, incluse durata, percentuale e gli eventuali riferimenti amministrativi inseriti;
- **documenti allegati:** giustificativi di trasferta e documenti relativi all'infortunio nei formati PDF, JPG, JPEG o PNG;
- **dati delle comunicazioni:** messaggi dell'amministrazione relativi ai fogli presenze e relativa data di lettura;
- **dati tecnici e di sicurezza:** token tecnici di autenticazione gestiti dal browser, dati necessari alla gestione delle richieste e, se registrati dall'infrastruttura o dal sistema di sessione, indirizzo IP, user agent, identificativi di sessione, data/ora e log di sicurezza;
- **dati tecnici della timbratura QR:** token temporaneo associato alla presenza, identificativo del dipendente e data della presenza. Il token QR ha, nella configurazione attuale, una validità predefinita di 30 secondi.

L'applicativo non richiede dati biometrici né utilizza il riconoscimento facciale o la geolocalizzazione.

Dati relativi alla salute e altre categorie particolari

Le causali **malattia**, **maternità** e **infortunio**, i relativi periodi, protocolli e documenti possono rivelare informazioni rientranti nelle categorie particolari di dati personali, in particolare dati relativi alla salute. Il Titolare deve limitarne la raccolta al minimo necessario: il personale che utilizza l'applicativo non deve inserire diagnosi, referti o ulteriori dettagli sanitari non necessari.

Il relativo trattamento è effettuato, ove necessario, per assolvere gli obblighi ed esercitare i diritti specifici del Titolare o dell'interessato in materia di diritto del lavoro e della sicurezza sociale e protezione sociale, ai sensi dell'articolo 9, paragrafo 2, lettera b), GDPR, sulla base della normativa nazionale applicabile. Il consenso del dipendente non costituisce, di regola, la base giuridica del trattamento necessario alla gestione del rapporto di lavoro.

4. Finalità e basi giuridiche

I dati sono trattati per le seguenti finalità:

1. **Gestione del rapporto di lavoro e dell'organizzazione aziendale**, inclusi anagrafica, contratti, orari, turni, ferie, permessi e presenze. La base giuridica è l'esecuzione del contratto e l'adempimento degli obblighi di applicabili, ai sensi dell'articolo 6, paragrafo 1, lettere b) e c), GDPR.
2. **Rilevazione e approvazione delle presenze**, anche tramite timbratura QR Code, e gestione delle causali di assenza. La base giuridica è l'articolo 6, paragrafo 1, lettere b) e c), GDPR e, per i dati particolari, l'articolo 9, paragrafo 2, lettera b), GDPR e la normativa applicabile.

3. **Elaborazione dei dati necessari a paghe, contributi, imposte e adempimenti assistenziali**, compresa l'esportazione dei dati delle presenze approvate verso il componente di esportazione paghe e verso eventuali consulenti incaricati. La base giuridica è l'adempimento di obblighi di legge, articolo 6, paragrafo 1, lettera c), GDPR.
4. **Gestione delle comunicazioni interne** relative alle presenze e alle richieste di correzione o approvazione. La base giuridica è l'esecuzione del rapporto di lavoro e l'adempimento degli obblighi applicabili.
5. **Sicurezza, autenticazione, prevenzione degli accessi abusivi e continuità del servizio**, inclusa la gestione dei token, dei log e dei controlli di autorizzazione. La base giuridica è il legittimo interesse del Titolare, articolo 6, paragrafo 1, lettera f), GDPR, bilanciato con i diritti e le libertà degli interessati.

Per queste finalità non è richiesto il consenso quando il trattamento è necessario per il rapporto di lavoro o per un obbligo di legge. Un eventuale trattamento ulteriore, non necessario per tali finalità, richiede una distinta base giuridica e sarà oggetto di informativa separata, ove necessario.

5. Modalità del trattamento e misure di sicurezza

Il trattamento avviene con strumenti informatici e telematici e, ove necessario, con supporti cartacei, da parte di soggetti autorizzati e secondo procedure di autorizzazione basate sui ruoli.

Nella configurazione applicativa attuale sono previste, tra le altre, le seguenti misure:

- autenticazione tramite cookie `auth_token` con attributi HttpOnly e SameSite=Strict; l'attributo Secure deve essere sempre attivo in produzione;
- revoca del token associato al logout e scadenza di 30 giorni per l'opzione “Ricordami”;
- trasmissione tramite HTTPS/TLS in produzione;
- controllo degli accessi alle API mediante autenticazione e ruoli;
- token QR a validità temporanea e token dedicato per la modalità kiosk;
- validazione dei tipi e delle dimensioni degli allegati caricati.

Il Titolare deve verificare prima della messa in produzione che HTTPS, Secure cookie, controllo degli accessi ai file e backup siano effettivamente configurati. Gli allegati possono contenere dati particolari e devono quindi essere accessibili solo a soggetti autorizzati, anche se l'infrastruttura usa un'area di memorizzazione pubblica o un URL diretto.

6. Destinatari e responsabili del trattamento

I dati non sono diffusi. Possono essere conosciuti, nei limiti delle rispettive funzioni, da:

- personale del Titolare autorizzato (Risorse Umane, amministrazione, direzione e responsabili competenti);
- fornitore dell'hosting, dell'infrastruttura, dei backup e della manutenzione applicativa, se presente, nominato Responsabile del trattamento ai sensi dell'articolo 28 GDPR;
- componente o servizio di esportazione paghe e consulente del lavoro/studio paghe, esclusivamente per i dati necessari agli adempimenti affidati e previa designazione o altro idoneo atto previsto dall'articolo 28 GDPR, quando applicabile;

- autorità, enti previdenziali, assistenziali e fiscali, quando la comunicazione è imposta dalla legge o da un provvedimento vincolante.

I nomi e i recapiti dei fornitori effettivamente utilizzati devono essere indicati nel registro dei trattamenti e, se opportuno, resi disponibili all'interessato mediante un elenco aggiornato.

7. Trasferimenti fuori dallo SEE

Il Titolare deve verificare l'ubicazione dei server e di tutti i subfornitori. Se i dati sono trasferiti fuori dallo Spazio Economico Europeo, il trasferimento avverrà solo nel rispetto del Capo V GDPR, mediante una decisione di adeguatezza o garanzie appropriate (incluse, ove applicabili, le clausole contrattuali standard) e con le eventuali misure supplementari necessarie.

Non è possibile confermare l'assenza di trasferimenti extra-SEE dalla sola configurazione del codice sorgente: tale informazione deve essere completata dal Titolare in base all'ambiente di hosting e ai contratti con i fornitori.

8. Periodi di conservazione

I dati sono conservati per il periodo indicato nella tabella seguente. Alla scadenza sono cancellati o anonimizzati, salvo che la conservazione sia necessaria per adempiere un obbligo di legge o per accertare, esercitare o difendere un diritto in sede giudiziaria. In quest'ultimo caso i dati sono conservati fino alla definizione del procedimento o della relativa pretesa.

Categoria di dati	Periodo di conservazione	Fonte normativa o criterio
Account e dati anagrafici	Per tutta la durata del rapporto e, dopo la cessazione, per 10 anni.	artt. 5, paragrafo 1, lettera e), e 13, paragrafo 2, lettera a), GDPR; art. 2946 c.c. (prescrizione ordinaria); obblighi di legge e tutela giudiziale dei diritti del Titolare.
Token di autenticazione	Fino alla scadenza del token o al logout, se anteriore. Il token persistente “Ricordami” scade dopo 30 giorni; il token non persistente è un cookie di sessione.	art. 5, paragrafo 1, lettere c) ed e), GDPR; durata tecnica configurata e revoca al logout.
Dati di sessione	Per la durata della sessione e comunque non oltre 120 minuti di inattività.	Durata tecnica configurata; artt. 5, paragrafo 1, lettera e), e 32 GDPR.
Presenze, ferie, permessi e approvazioni	Per la durata del rapporto e per 5 anni dalla cessazione. In caso di contenzioso, fino alla definizione.	art. 39 del D.L. 112/2008 (Libro unico del lavoro); art. 2948, n. 4, c.c. (prescrizione dei crediti di lavoro); artt. 5, paragrafo 1, lettera e), e 13, paragrafo 2, lettera a),

Categoria di dati	Periodo di conservazione	Fonte normativa o criterio
		GDPR. Restano salvi termini speciali più lunghi.
Dati trasmessi per le paghe	Per 10 anni dalla chiusura dell'esercizio di riferimento, o per il diverso termine previsto dalla normativa fiscale, contributiva o civilistica.	art. 2220 c.c.; art. 22 del D.P.R. 600/1973; termini di accertamento e prescrizione applicabili; artt. 5, paragrafo 1, lettera e), e 13, paragrafo 2, lettera a), GDPR.
Malattia, infortunio e relativi allegati	Per il tempo necessario a gestire l'assenza e, di regola, per 5 anni dalla cessazione. Fino a 10 anni se connessi a infortunio sul lavoro o contenzioso. Alla scadenza, cancellazione o anonimizzazione.	art. 9, paragrafo 2, lettera b), GDPR; obblighi in materia di lavoro e sicurezza sociale; artt. 5, paragrafo 1, lettere c) ed e), e 17 GDPR. L'art. 25 del D.Lgs. 81/2008 disciplina la cartella sanitaria del medico competente, distinta dagli allegati dell'applicativo.
Log di sicurezza	12 mesi dalla generazione, salvo estensione limitata al tempo necessario per incidenti, verifiche o accertamenti in corso.	artt. 5, paragrafo 1, lettere c) ed e), e 32 GDPR; provvedimento del Garante del 27 novembre 2008 sui log degli amministratori di sistema, ove applicabile.
Backup	30 gg. secondo il ciclo ordinario di rotazione, oppure 90 gg. se previsto e documentato dal Titolare. Alla scadenza, cancellazione o sovrascrittura automatica.	artt. 5, paragrafo 1, lettera e), e 32 GDPR; criterio tecnico di sicurezza, ripristino e continuità operativa definito dal Titolare.

I termini indicati si applicano solo ai dati necessari per la finalità descritta e non autorizzano la conservazione indiscriminata di ogni informazione contenuta nella categoria. Obblighi o termini speciali diversi prevalgono sui termini generali sopra indicati.

9. Diritti dell'interessato

L'interessato può esercitare, nei casi e alle condizioni previste dagli articoli 15 e seguenti GDPR:

- accesso ai dati e alle informazioni sul trattamento (articolo 15);
- rettifica dei dati inesatti o integrazione di quelli incompleti (articolo 16);
- cancellazione, quando ne ricorrono i presupposti e non sussistono obblighi di conservazione (articolo 17);
- limitazione del trattamento (articolo 18);
- portabilità dei dati, quando applicabile (articolo 20);
- opposizione ai trattamenti fondati sul legittimo interesse (articolo 21);
- non essere sottoposto a una decisione basata unicamente su un trattamento automatizzato con effetti giuridici o analogamente significativi, salvo i casi previsti dall'articolo 22.

Le richieste possono essere inviate a **[E-MAIL PRIVACY]** o all'indirizzo **[INDIRIZZO POSTALE]**. Il Titolare risponde nei termini previsti dal GDPR e può chiedere informazioni necessarie a verificare l'identità del richiedente.

L'interessato ha inoltre diritto di proporre reclamo al Garante per la protezione dei dati personali (www.garanteprivacy.it), fatta salva ogni altra tutela amministrativa o giurisdizionale.

10. Aggiornamenti

La presente informativa sarà aggiornata in caso di modifiche alle funzionalità di HR-Tech ERP, ai fornitori, all'infrastruttura, ai trattamenti effettuati o alla normativa applicabile. La versione vigente deve essere resa facilmente accessibile agli interessati.